Lesson 1: Foundational Concepts of Security 🛡️

- **1.1 General and Computer Security**
  - Definition of **Security**: A state of being secure and free from danger or harm; also, the actions taken to make someone or something secure.
  - Introduction to **Computer Security**: The historical predecessor to information security.
  - Evolution to **Information Security**: Expansion of scope beyond just computers to protecting all information assets in an organization.
  - Key Objectives of Computer/Information Security:
    - Securing the data.
    - Limiting random and unauthorized access to that data.
    - Involving personnel from multiple levels of the organization.

Lesson 2: Core Models and History of Information Security ⏳

- **2.1 History of Information Security**
  - Overview of the timeline and key developments:
    - Before 1960s (Early days).
    - 1960s.
    - 1970s and 1980s.
    - **1990s and the Internet:** The Internet was made available to the public, security was initially a low priority, leading to problems like insecure email. Rise of antivirus products.
    - 2000 to Present (Modern challenges and advancements).
- **2.2 The CIA Triangle**
  - Introduction to the **C.I.A. Triangle**: The industry standard for computer security since the mainframe development.
  - The Three Core Characteristics of Information Utility:
    - **Confidentiality:** Preventing unauthorized disclosure of information.
    - **Integrity:** Preventing unauthorized modification of information.
    - **Availability:** Ensuring timely and reliable access to and use of information.
- **2.3 Key Information Security Concepts**
  - Exploration of other critical terminology (implied by the visual cues in the slides, such as threats, hackers, vulnerability, credit card security).
  - *Note: This section would define terms like Threat, Vulnerability, Risk, Attack, Asset, etc., to fully cover the basics.*

Lesson 3: Information Systems and Security Architecture 💻

INFOSECNU

- **3.1 Components of an Information System**
  - Definition of an **Information System**: The entire set of software, hardware, data, people, procedures, and networks that enable the use of information resources.
  - Identifying the six core components:
    - Hardware
    - Software
    - Networks
    - Data
    - People
    - Procedures
- **3.2 The McCumber Cube**
  - Introduction to the **McCumber Cube**: A graphical representation of the architectural approach widely used in computer and information security.
  - Understanding the three axes:
    - **The three C.I.A. goals:** Confidentiality, Integrity, Availability.
    - **States of Information:** Storage, Processing, Transmission.
    - **Security Safeguards (Countermeasures):** Policy, Education, Technology.
- **3.3 Approaches in Information Security**
  - **Top-down approach:** Security initiatives driven by management (CEO, CIO, CISO) and mandated downward through the organizational hierarchy.
  - **Bottom-up approach:** Security initiatives originating from technical staff (security techs/admins) attempting to improve security. *(The Top-down approach is generally more successful).*

Information Security Systems Development Life Cycle (SecSDLC)

The **Security Systems Development Life Cycle (SecSDLC)** is a methodology for the design and implementation of an information security system. It closely follows the steps of the traditional Systems Development Life Cycle (SDLC) but focuses specifically on the security components of the system.

Phases of the SecSDLC

The SecSDLC follows a cyclical, iterative process, as shown in the provided waterfall diagram:

1. **Investigation**
2. **Analysis**
3. **Logical Design**
4. **Physical Design**

INFOSEC NU

5. **Implementation**
6. **Maintenance and Change**

1. Investigation Phase

The **Investigation** phase initiates the security project. It involves defining the scope and goals, estimating costs, and evaluating existing resources.

- **Common SDLC/SecSDLC Steps:** Outline project scope and goals, estimate costs, evaluate existing resources, and analyze feasibility.
- **Unique SecSDLC Steps: Management defines project processes and goals** and documents these in the **program security policy**.

2. Analysis Phase

The **Analysis** phase focuses on thoroughly examining the current security posture, threats, and requirements.

- **Common SDLC/SecSDLC Steps:** Assess the current system, develop preliminary system requirements, study integration of the new system with the existing one, and document findings.
- **Unique SecSDLC Steps:**
    - **Analyze existing security policies and programs.**
    - **Analyze current threats and controls.**
    - **Examine legal issues** relevant to the organization.
    - **Perform risk analysis** to identify and prioritize risks to assets.

3. Logical Design Phase

The **Logical Design** phase takes the requirements from the Analysis phase and develops the abstract, technology-independent blueprints for the security solution.

- **Common SDLC/SecSDLC Steps:** Assess business needs, select applications and data structures, generate multiple alternative solutions for consideration, and document findings.
- **Unique SecSDLC Steps (Planning Focus):**
    - Develop the **security blueprint**.
    - **Plan incident response actions** (What steps are taken when an attack occurs?).
    - **Plan business response to disaster** (Disaster recovery: What must be done to recover?).
    - **Determine feasibility of continuing and/or outsourcing** the project.

4. Physical Design Phase

INFO SEC NU

The **Physical Design** phase evaluates and selects the specific hardware, software, and controls—the **information security technology**—needed to support the logical design blueprint.

- **Common SDLC/SecSDLC Steps:** Select technologies to support solutions, select the best solution, decide to *make or buy* components, and document findings.
- **Unique SecSDLC Steps:**
    - Select **specific technologies** needed to support the security blueprint.
    - Develop a **definition of a successful solution**.
    - Design **physical security measures** (e.g., locks, environmental controls) to support technological solutions.
    - **Review and approve** the project for the next phase.

5. Implementation Phase

The **Implementation** phase is where the security solutions are built or bought, installed, configured, and tested.

- **Common SDLC/SecSDLC Steps:** Develop or buy software, order components, document the system, train users, test the system, and present it to users.
- **Unique SecSDLC Steps:**
    - **Acquire, test, and implement** the security solutions.
    - Evaluate **personnel issues** and conduct specific **training and education programs**.
    - Present the **entire tested package to upper management for final approval**.

6. Maintenance and Change Phase

This is the **most important phase** due to the ever-changing threat environment. It's a continuous, defensive effort to monitor, test, modify, and repair the system to ensure its continued viability.

- **Common SDLC/SecSDLC Steps:** Support and modify the system, test periodically for compliance, and upgrade/patch as necessary.
- **Unique SecSDLC Steps:**
    - **Constantly monitor, test, modify, update, and repair** to meet changing threats.
    - The focus is on **repairing damage and restoring information** against an unseen adversary.
    - The loop feeds back to the Investigation phase when the system is **no longer viable**.

INFO SEC NU

The NIST Approach to Securing the SDLC

The **National Institute of Standards and Technology (NIST)** offers a structured approach to integrating security into the full system development life cycle, emphasizing security considerations at every stage.

NIST Phase	Focus & Security Activities
1. Initiation	Security is viewed in terms of **business risks**. Activities include: initial delineation of requirements (Confidentiality, Integrity, Availability), determining **information categorization**, identifying special handling, and determining **privacy requirements**.
2. Development/Acquisition	Designing and testing the security aspects. Activities include: conducting the **risk assessment** to supplement baseline controls, analyzing security requirements, performing functional and **security testing**, designing the **security architecture**, and preparing initial documents for certification and accreditation.
3. Implementation/Assessment	Installing the system and evaluating it in the operational environment. Activities include: integrating the system, planning and conducting **system certification** (testing security controls), and completing **system accreditation** activities (formal management authorization to operate).

INFOSECNU

4. Operations and Maintenance	Ongoing protection, monitoring, and enhancement. Activities include: conducting an **operational readiness review**, **configuration management**, continuous monitoring of security controls, and performing **reauthorization** as required.
5. Disposal	Orderly termination of the system and preservation of vital information. Activities include: building and executing a **disposal/transition plan**, **archival of critical information**, **sanitization of media**, and disposal of hardware/software.

Information Security Communities of Interest

Successful information security relies on the collaboration of several groups within the organization, known as **Communities of Interest**, who share a common goal of helping the organization meet its objectives.

Senior Management Roles

Role	Description
Chief Information Officer (CIO)	An **executive-level position** that oversees the organization's computing technology, aiming for efficiency in processing and accessing information.
Chief Information Security Officer (CISO)	The **top information security officer** in an organization. Often reports to the CIO and is typically not an executive-level position. The CISO's roles often span **Policy, Risk Management, and Technology**.

Key Communities of Interest

- **Information Security Management and Professionals:**

INFO SEC NU

    - Focus: **Protecting the organization's information systems and stored information from attacks**. Their roles are aligned with the goals and mission of the information security community.
- **Information Technology Management and Professionals:**
    - Focus: Systems design, programming, and networking. Their focus is on **costs of system creation/operation, ease of use, and timeliness/response time** of system creation.
- **Organizational Management and Professionals:**
    - Focus: General management and all other organizational resources (e.g., Executive Management, Human Resources, Accounting, Legal Staff). They provide the **business context, resources, and policy support** necessary for security to succeed.

Data Responsibilities

Different roles are responsible for different aspects of data:

- **Data Owner:** An organizational leader responsible for the **protection and use of a specific subset of information**. They are typically senior managers.
- **Data Custodian:** Responsible for the **storage, maintenance, and protection of the information**. They perform tasks like implementing security controls, backups, and recovery, usually following the Data Owner's direction.

The text you provided explains the core purpose of an information security program and defines the essential terms that justify the need for security in any organization.

The Need of Security

The **primary mission** of an information security program is to ensure that **information assets** remain **safe and useful**. This mission is directly tied to the fundamental security goals of **Confidentiality, Integrity, and Availability (CIA)**.

Key Definitions

The need for security is rooted in distinguishing between raw facts and valuable organizational property:

- **Data** : These are the raw building blocks—items of fact collected by an organization. Data includes raw numbers, facts, and words.
    - *Example: A list of temperature readings.*
- **Information** : This is **Data that has been organized, structured, and presented** to provide additional insight into its context, worth, and usefulness.

INFO SEC NU

    - *Example: The temperature readings, when analyzed to show a trend of rising temperatures over a decade, become information.*
- **Information Asset** : This is the ultimate **focus of information security**. It is information that has **value to the organization**, and it also includes the **systems that store, process, and transmit** the information.
- **Data Security** : Commonly used as a surrogate for information security, this is the focus of **protecting data or information in its various states**:
    - **At rest** (in storage).
    - **In processing**.
    - **In transmission** (over networks).
- **Database Security** : A subset of information security that specifically focuses on the **assessment and protection of information stored in data repositories** like database management systems and storage media.

Four Critical Functions of Information Security

Information security performs four important functions for an organization:

1. **Protecting the organization's ability to function**. Security ensures that critical systems and processes are available and operational, fulfilling the **Availability** goal of the CIA triad.
2. **Protecting the data and information the organization collects and uses**. This is the core task of preserving the **Confidentiality** and **Integrity** of the information assets.
3. **Enabling the safe operation of applications** running on the organization's IT systems. Security ensures software is free from **Vulnerabilities** and **Attacks** that could compromise data or system function.
4. **Safeguarding the organization's technology asset**. This involves protecting the **Hardware** and **Software** that make up the Information System, as these are the physical and logical components that house and handle the data.

1. Compromises to Intellectual Property (IP)

This is about stealing or misusing original ideas, designs, or code that belong to a company.[1] It's theft of the mind's work.

- **Software Piracy and Copyright Infringement (CI):** Illegally copying or distributing software or media.[2]
    - **Analogy:** It's like illegally sharing a copy of a textbook with your entire class instead of each person buying one.

INFO SEC NU

2. Deviations in Quality of Service (QoS)

This happens when a crucial service you pay for (like internet or power) fails or works poorly, disrupting your business.

- **Example Scenario:** Your company relies on an **Internet Service Provider (ISP)**.[3] If the ISP's main fiber optic cable is accidentally cut by a construction crew, your company goes offline, halting all sales. This is a severe deviation in QoS.

3. Espionage or Trespass (Hacker)

This is unauthorized access to systems or data, like a burglar breaking into a digital house.

Hacker Categories (By Skill)

- **Expert Hacker:** The highly skilled architects who design the digital "lock-picking" tools (**Exploits**). They find new, unknown vulnerabilities (**Zero-Days**).

- **Novice Hacker (Script Kiddie):** Uses the ready-made tools and instructions created by the Experts. They are not developers; they are simply users of hacking tools.

Hacker Variants (By Motivation)

- **Cracker:** Focuses on removing or bypassing software copyright protections (like anti-piracy features).

- **Phreaker:** Focuses on manipulating the public telephone system (an old threat, but the concept applies to voice-over-IP systems today).

Password Attacks (Cracking)

This is about figuring out a person's digital key. **Cracking** is the process of trying to guess or reverse-engineer a password.

1. **Brute Force Attacks:** Trying every single possible combination of characters until the right password is found. **Analogy:** Trying every single key on a massive keyring in a lock.

INFO SEC NU

2. **Dictionary Attacks:** Trying combinations based on common words, names, or phrases.

Analogy: Trying the most common house keys first (e.g., "123456" or "password").

3. **Rainbow Tables:** Using pre-calculated lists to quickly reverse a hashed (encrypted) password back to the original text. **Analogy:** A cheat sheet for known lock combinations.

4. **Social Engineering Attack:** Using psychological manipulation, not technical skill, to trick a person into giving up their password.[6] **Analogy:** Calling someone and pretending to be from tech support to get their login information.

4. Forces of Nature

Unpredictable environmental events that cause damage.

- **Example Scenario:** A **lightning strike** hits a transformer near your data center, causing a power surge that fries critical network hardware.

5. Human Error or Failure

Mistakes made by employees that unintentionally compromise security.
This is often an insider threat.

- **Example Scenario:** An employee mistakenly attaches a spreadsheet containing the salaries of all senior managers to an email that was supposed to go to a vendor outside the company.

6. Information Extortion (Cyberextortion)

The act of stealing information and demanding money (or compensation) to return it or keep it secret.

- **Example Scenario:** An attacker steals customer credit card data and threatens to release it publicly unless the company pays a massive **ransom** (often using **Ransomware** to encrypt the files first).[9]

7. Sabotage or Vandalism

Deliberate destruction or defacement of a system or an organization's image.

INFO SEC NU

Online Activism (Ideological Attacks)

These are attacks motivated by political, social, or religious goals.

- **Cyberterrorist:** Attacks systems (like power grids or hospitals) to cause widespread fear and disruption, typically targeting civilian infrastructure.[10]
- **Cyberwarfare:** Nation-state sponsored attacks against the information systems of an enemy government (e.g., military networks, defense contractors).[11]

8. Software Attacks

The deployment of malicious software (**Malware**) to compromise a system.

Malware Types

Malware Type	What It Does (Analogy)	Example
Adware	Floods you with unwanted pop-up ads.	Annoying ads that hijack your web browser.
Spyware	Secretly monitors your activity (keystrokes, logins) and sends the data back to the attacker.	A hidden program that records your bank login when you type it.
Trojan Horse	Disguises itself as a legitimate file (like a game) to trick you into installing it.	A "free game download" that secretly installs a backdoor on your system.

INFO SEC NU

Virus	Attaches to a legitimate program and needs you to run the host program to spread.	A file attached to an email that only infects your PC when you open the file.
Worm	Self-replicates and spreads autonomously across a network without needing a host file or user action.	A piece of code that finds an unprotected computer on the network and jumps to it, multiplying quickly.
Backdoor	A hidden access point installed in software to allow a threat actor to bypass normal security controls later.	A secret remote-access tool planted by a system designer for future use.
DoS/DDoS Attack	**Denial of Service** (DoS) or **Distributed DoS** (DDoS) floods a server with massive traffic to crash it, disrupting **Availability**.	Millions of fake requests crash a university's course registration portal on the first day of sign-ups.
Email Attacks	Includes **Spam** (unwanted bulk mail) and **Mail Bombs** (sending so much mail it crashes the mail server).	Receiving a wave of identical, oversized emails that congest your server.

INFO SEC NU

Communication Interception Attacks

Attacks that focus on stealing or manipulating data *while it is moving* across a network.

- **Packet Sniffer:** A tool used to capture data packets traveling over a network (like digital eavesdropping).
    - **Example:** Using a sniffer on unencrypted public Wi-Fi to capture a user's login credentials.
      Pharming: Redirecting users to a fake website, even if they type the correct URL, usually by corrupting the local DNS settings.
    - **Example:** A user types their bank's URL, but the pharming attack sends them to a fake, identical login page to steal their credentials.
- **Spoofing:** Faking the identity of a legitimate source.
    - **Example: Email Spoofing** is when an email appears to come from your CEO, but it actually came from an attacker trying to trick you into sending money (**Social Engineering**).

9. Technical Hardware Failures or Errors

Malfunctions in the physical equipment itself.

- **Example:** A **hard drive crash** in a critical server that leads to data **Loss** and system downtime.

10. Technical Software Failures or Errors

Unintended bugs or flaws in the code of the operating system or applications.

- **Example:** A **software update** introduces a bug that causes the entire application to crash every time a user saves a file, or a code flaw allows an attacker to take control of the system.

11. Technological Obsolescence

Using old technology that is no longer supported or patched by the vendor, leaving it highly vulnerable.

INFO SEC NU

- **Example:** Relying on a server running an ancient Operating System (like Windows Server 2003) because a legacy application can't be updated. This system cannot receive security patches, making it an easy target.

12. Theft

The illegal confiscation of physical property or information.

- **Example:** A company **laptop is stolen** from an employee's car. If the hard drive wasn't encrypted, the confidential **data** on it is also lost to the thief.

Data Protection Law and Global Scope

This module explores the framework of major international data protection regulations and the role of the Philippine National Privacy Commission (NPC) in the global privacy landscape.

I. GDPR and DPA: Foundational Privacy Laws

The **General Data Protection Regulation (GDPR)** and the **Data Privacy Act (DPA)** are cornerstones of modern data protection, fundamentally changing how organizations handle personal data.

🇪🇺 General Data Protection Regulation (GDPR)

The GDPR is a regulation in EU law on data protection and privacy for all individual citizens of the European Union (EU) and the European Economic Area (EEA).

- **Objective:** To give individuals control over their personal data and to simplify the regulatory environment for international business by unifying the regulation within the EU.
- **Key Principles:** Lawfulness, fairness and transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality (security), and accountability.
- **Rights of the Data Subject:** Includes the right to access, the right to rectification, the **right to erasure** (or 'right to be forgotten'), the right to restriction of processing, and the **right to data portability**.

🇵🇭 Data Privacy Act of 2012 (DPA, or RA 10173)

The DPA is the comprehensive data privacy law in the Philippines, enforced by the National Privacy Commission (NPC).

- **Objective:** To protect the fundamental human right of privacy, while ensuring free flow of information to promote innovation and growth.

INFO SEC NU

- **Scope:** Protects **Personal Information** and **Sensitive Personal Information** handled by both the government and private sector.
- **NPC's Role:** The **National Privacy Commission (NPC)** is the independent body mandated to administer and implement the DPA, and to monitor and ensure the country's compliance with international standards.

II. Scope and Extraterritoriality

The Scope of GDPR

GDPR applies broadly to any organization that processes personal data.

- **Applicability within the EU:** Any company established in the EU, regardless of where the data processing takes place.
- **Applicability outside the EU (Extraterritorial Scope):** This is one of GDPR's most significant features. It applies to organizations **outside the EU** if they:
    1. Offer goods or services to individuals in the EU (even if for free).
    2. Monitor the behavior of individuals in the EU (e.g., tracking website visitors).

Impact Note: Due to this extraterritorial reach, many multinational corporations, including those based in the Philippines that process data of EU residents, must comply with GDPR standards.

III. Philippine NPC in the International Arena

The **National Privacy Commission (NPC)** actively participates in international privacy organizations to harmonize data protection standards and facilitate cross-border data flows, demonstrating the Philippines' commitment to global best practices.

Participation in International Associations

Organization	NPC's Role/Involvement	Significance
Council of Europe's Convention 108	NPC is involved in efforts to modernize **Convention No. 108**, the first legally binding international treaty in the area of data protection.	Ensures Philippine standards align with fundamental European data protection principles.

INFOSECNU

International Conference of Data Protection & Privacy Commissioners (ICDPPC)	The NPC is **accredited** by the ICDPPC (now known as the Global Privacy Assembly or GPA).	Accreditation signifies that the NPC meets high international standards for independence and effectiveness as a privacy regulator.
Global Privacy Enforcement Network (GPEN)	The Philippines (PH) is a **member** of GPEN.	A network for cross-border cooperation in the enforcement of privacy laws among member authorities.
Asia Pacific Privacy Authorities (APPA)	The PH is a **member** of APPA.	Fosters cooperation and information sharing among privacy regulators in the Asia Pacific region.
APEC Cross-Border Privacy Rules (CBPR) System	NPC is actively seeking membership and participating in the CSEA (Cross-Border Privacy Enforcement Arrangement).	Allows organizations to demonstrate compliance with a recognized framework, facilitating secure and accountable cross-border data transfer within APEC economies.

INFOSEC NU

IV. Legislative Liaisons and National Initiatives

The NPC works closely with the Philippine legislature to ensure that new national laws and amendments incorporate strong privacy and data protection measures.

Key Legislative Liaison Areas

- **National I.D. System:** Ensuring the Philippine Identification System (PhilSys) incorporates privacy-by-design principles.

- **Mobile Number Portability:** Providing guidelines for data handling during number transfers to protect subscriber information.
- **SIM Card Registration:** Liaising to ensure registration requirements comply with data minimization and security standards.
- **Privacy of Communications:** Advising on policies that affect the confidentiality and security of digital communications.
- **Amendment of Cybercrime Law:** Working to update the law to effectively combat cybercrimes while respecting constitutional rights to privacy.

Legal, Ethical, and Professional Issues in Information Security

Information security professionals must navigate a complex landscape governed by law, ethics, and professional standards. This module breaks down these distinct but interconnected areas.

I. Law and Organizational Liability

The legal framework defines mandatory security requirements and penalties for failure to protect information assets.

Defining Liability

- **Liability** is the legal obligation of an entity (person or organization) that extends beyond criminal or contract law.
- It includes the obligation to make **restitution** for wrongs committed, such as damages resulting from a security breach due to negligence.
- Organizations have a **legal obligation** to protect the confidentiality, integrity, and availability (CIA) of the information they hold. Failure to do so exposes them to significant legal and financial risk, emphasizing the **need for legal counsel** in developing security programs.

Policy Versus Law

Feature	Law	Policy
Source	Legislature (government)	Organization's Management
Scope	Applies to all citizens/entities within a jurisdiction	Applies only to users and employees within the organization

INFOSEC NU

Enforcement	Police, Courts, Regulatory Agencies	Internal HR/Management, Sanctions, Termination
Requirement	**Mandatory** compliance (failure = criminal/civil penalties)	**Mandatory** compliance *within the organization* (failure = disciplinary action)
Goal	Establish the minimum standard of acceptable behavior.	Detail the acceptable use of IT assets and enforce security practices.

Types of Law

Law can be categorized in several ways, determining jurisdiction, penalties, and enforcement mechanisms:

Category	Focus	Relationship Governed	Penalty/Enforcement
Civil Law	Relationships and conflicts between organizations and people.	Person vs. Person or Person vs. Organization.	**Restitution** (e.g., monetary damages).
Criminal Law	Activities and conduct harmful to society.	State vs. Individual/Organization.	Fines, Imprisonment, or both (actively enforced by the state).
Public Law	Structure and administration of government agencies and their	Government vs. Citizen/Employee/Other Government.	Governs areas like constitutional and administrative law.

INFOSEC NU

	relationships with citizens.		
Private Law	Relationships between individuals and organizations.	Individual vs. Organization.	Encompasses family, commercial, and labor law.

II. Key U.S. Laws Relevant to Information Security

Many influential U.S. laws establish precedents for security and privacy, often with global impacts due to the multinational nature of technology firms.

Area	**Act (Year)**	**Description**
Health Data	**HIPAA** (1996)	Requires medical practices to ensure the **privacy and security** of personal medical information (PHI).
Financial Reporting	**SOX** (2002)	**Sarbanes-Oxley Act** enforces accountability for executives at publicly traded companies; impacts IT control and data integrity.
Privacy/PII	**Federal Privacy Act** (1974)	Governs federal agency use of **Personally Identifiable Information (PII)**.
Intellectual Property	**Copyright Act** (1976)	Protects intellectual property, including published programs and software.

INFO SEC NU

Cybercrime	**Computer Fraud and Abuse Act (CFAA)** (1986)	Defines and formalizes laws to counter threats from computer-related acts.
Digital Media	**Digital Millennium Copyright Act (DMCA)** (1998)	Provides specific penalties for removing copy protection from media.
Federal Security	**FISMA** (2002)	**Federal Information Security Management Act** specifies requirements for federal agencies to establish comprehensive information security programs.

Personally Identifiable Information (PII)

PII is information that can be used on its own or with other information to identify, contact, or locate a single person. Protecting PII is the goal of many modern laws.

- **Basic Identifiers:** Name, Address, Email, Phone Number.
- **Identification Numbers:** Social Security Number, Driver's License Number, Passport Number.
- **Financial Information:** Credit Card Numbers, Bank Account Details.
- **Biometric Data:** Fingerprints, Facial Recognition Data, Iris Scans.
- **Online Identifiers:** IP Addresses, Usernames, online activity traceable to an individual.

Standards (Not Law)

- **PCI DSS (Payment Card Industry Data Security Standard):** A **set of contractual requirements**, not a law, enforced by major credit card brands. It mandates specific security controls for any entity that stores, processes, or transmits cardholder data.

III. Ethics and Professionalism

While law establishes what you **must** do, ethics defines what you **should** do, based on moral principles.

The Ten Commandments of Computer Ethics (Computer Ethics Institute)

These commandments serve as a general ethical guide for IT professionals and users:

INFO SEC NU

1. Thou shalt **not** use a computer to harm other people.[1]
2. Thou shalt **not** interfere with other people's computer work.[2]
3. Thou shalt **not** snoop around in other people's computer files.[3]
4. Thou shalt **not** use a computer to steal.[4]
5. Thou shalt **not** use a computer to bear false witness.[5][6]
6. Thou shalt **not** copy or use proprietary software for which you have not [7]paid.[8]
7. Thou shalt **not** use other people's computer resources without authorization or proper compensation.[9]
8. Thou shalt **no[10]t** appropriate other people's intellectual output.
9. Thou shalt **think about the social consequences** of the program you are writing or the system you are designing.
10. Thou shalt always use a computer in ways that ensure **consideration and respect** for your fellow humans.

Deterring Unethical and Illegal Behavior

Effective security programs deter malicious or careless behavior through:

- **Education:** Training users on policies, laws, and ethical expectations.
- **Deterrence:** Implementing controls that discourage misconduct (e.g., monitoring, access restrictions).
- **Enforcement:** Clearly communicating and consistently applying penalties (disciplinary action, termination, or legal prosecution).

Major Information Security Professional Organizations

Professional organizations set codes of ethics and standards for the industry, fostering professionalism and competence.

Organization	**Focus/Description**
Association of Computing Machinery (ACM)	Focus on the **ethics of security professionals**; publishes a comprehensive code of 24 imperatives.
Information Systems Audit and Control Association (ISACA)	Focus on **auditing, information security, and governance**; administers the CISA and CISM certifications.

INFO SEC NU

(ISC)²	International consortium for improving the quality of security professionals; administers the **CISSP** and **SSCP** certifications, requiring adherence to its Code of Ethics.
SANS Institute's GIAC	Focuses on deep **technical security training** and certification, requiring certificants to follow its code of ethics.

Information Security Planning and Governance

Effective information security requires a structured approach that aligns with the organization's business objectives, guided by a clear strategy and robust governance structure.

I. Strategic Planning Hierarchy

Strategic Planning is the long-term process senior management uses to specify the organization's overall goals, objectives, future direction, and resource allocation. Security planning must mirror this organizational hierarchy.

The Three Levels of Planning

Planning Level	Scope/Timeframe	Responsible Level	Purpose
Strategic Planning	**Long-Term** (Several Years)	Senior/Executive Management	Defines **long-term goals** and the overall direction of the organization's security posture.

INFO SEC NU

Tactical Planning	**Intermediate-Term** (Few Years)	Management/Department Heads	Defines **intermediate objectives** needed to achieve the strategic goals; includes resource scheduling.
Operational Planning	**Short-Term/Day-to-Day** (Several Months)	Operational/Supervisory Management	Defines **short-term goals** and **daily actions** necessary to execute the tactical plans; focuses on specific tasks and resource allocation.

Goals vs. Objectives: While often used synonymously, a **Goal** is generally viewed as the desired *end* of the planning cycle (the ultimate destination), whereas an **Objective** is an *intermediate state* achieved to make progress toward the final goal (the milestones along the way).

The Role of the CISO in Planning

The Chief Information Security Officer (CISO) and the security management team's **first priority** is the creation of a **strategic plan** for information security. This plan must articulate how security supports the organization's overall mission and risk tolerance.

II. Information Security Governance

Governance ensures that the strategic security plan is implemented, managed, and monitored effectively from the top down.

Defining Governance

- **Corporate Governance:** The responsibilities and practices exercised by the board and executive management to provide strategic direction, ensure objectives are achieved, manage risks, and confirm responsible resource use.

INFO SEC NU

- **Information Security Governance:** The application of the principles of corporate governance specifically to the **information security function**. It makes security an executive-level responsibility, not just a technical IT issue.

The Five Key Goals of Information Security Governance

1. **Strategic Alignment:** Ensuring information security directly supports and integrates with the overall business strategy and objectives.
2. **Risk Management:** Implementing appropriate measures to identify, manage, and mitigate threats to information resources.
3. **Resource Management:** Using security knowledge, infrastructure, and budget **efficiently and effectively**.
4. **Performance Measurement:** Establishing metrics to measure, monitor, and report on security effectiveness to ensure objectives are achieved (**security metrics**).
5. **Value Delivery:** Optimizing information security investments to generate the maximum possible benefit and support organizational objectives.

III. Policy, Standards, Guidelines, and Procedures (PSGP Hierarchy)

Policy is the **foundation** of the entire security planning effort, serving as the high-level management directive. This foundation is built upon by standards, guidelines, and procedures.

The Security Documentation Hierarchy

The relationship between these components is often visualized as a pyramid, with **Policies** at the top, supported by more granular documents.

Component	Level of Detail	Authority/Goal	Example (Password)
Policy	**High-Level Directive**	Management-sanctioned rule to protect assets.	"Employees must use strong passwords on their accounts."
Standards	**Detailed, Mandatory Specifications**	The minimum specific requirements for compliance.	"Passwords must be at least 10 characters long and include

INFO SEC NU

			alphanumeric characters."
Guidelines	**Recommended Actions**	Advice or suggestions to assist users in complying with policy and standards.	"To create strong, yet easy-to-remember passwords, use a passphrase."
Procedures	**Step-by-Step Instructions**	Detailed, required steps for performing a specific task.	"To change your password, click [Tools], select [Change Password], then follow steps 1-5."
Practices	**Industry Exemplars**	Actions or methods identified by other reputable organizations as ideal and sought to be emulated.	"US-CERT recommends a minimum password length of 15 characters for administrator accounts."

IV. Types of Information Security Policies (NIST SP 800-14)

Management must define security policies at three distinct levels to ensure comprehensive coverage:

1. Enterprise Information Security Policy (EISP)

The EISP is the **highest-level policy** created by senior management. It sets the strategic tone for the entire security program.

- **Content:**
  - Overview of the corporate philosophy on security.
  - Structure of the security organization and roles.
  - **Shared Responsibilities** for security (for all employees, contractors, etc.).
  - **Unique Responsibilities** for security (specific to each role).

INFO SEC NU

- **Compliance Focus:** Addresses general compliance for establishing the security program and specifying **penalties and disciplinary action** for non-compliance.

2. Issue-Specific Security Policies (ISSP)

The ISSP addresses a specific, frequently encountered, or high-risk technology or organizational issue.

- **Examples:** Acceptable Use Policy (AUP), Email Security Policy, Internet Use Policy, Remote Access Policy.

3. Systems-Specific Security Policies (SysSP)

The SysSP focuses on the security requirements for **individual technology systems, applications, or networks**. It is further divided into two groups:

SysSP Type	Perspective	Focus	Implementation Method
Managerial Guidance SysSP	**Business**	Management's intent for the acquisition, configuration, and use of a specific technology (e.g., "All web servers must use TLS 1.3 or higher").	Access Control List (ACL)
Technical Specifications SysSP	**Technical**	Detailed instructions for the technical implementation, written as configuration rules and systems policies (e.g., the exact firewall port settings).	Configuration Rules

Methods of Implementing Technical Controls:

- **Access Control List (ACL):** A specification that defines which users or systems can access a specific information asset and what rights (read, write, execute) they have.

INFOSEC NU

- **Configuration Rules:** The specific instructions coded into a device (like a firewall, server, or router) that dictate its operational behavior and security controls.

Policy Management, Architecture, and SETA

Information security relies on documentation to define the rules, architecture to implement them, and people to execute them.

I. Policy Management: Maintaining Living Documents

Security policies are **living documents** that must be actively managed to remain effective. Proper management ensures they are correctly distributed, understood, and uniformly applied.

Key Components of Security Policy Management

Component	Description	Importance
Responsible Manager (Policy Administrator)	An employee responsible for the **creation, revision, distribution, and storage** of a policy. This person ensures the policy lifecycle is managed.	Centralizes accountability and ensures policies are consistently maintained.
Schedule of Reviews	Policies must be **periodically reviewed** for currency and accuracy. If they become outdated, they can turn into organizational **liabilities**.	Ensures rules remain relevant to the evolving threat landscape and business operations.
Review Procedures and Practices	Implementing a mechanism (like email, anonymous drop box) for stakeholders to comfortably recommend revisions. All comments should be examined and approved improvements implemented.	Fosters a participatory culture and ensures policies are practical for the people who must follow them.

INFO SEC NU

Policy and Revision Date	Policies must be clearly **dated** to avoid confusion about which version is currently active.	Provides a critical audit trail and resolves conflicts between different versions.
Sunset Clause	A component that defines an expected **expiration date** for the policy's applicability. Often used for policies governing short-term associations or specific projects.	Prevents obsolete policies from remaining enforced indefinitely.

Automated Policy Management

The necessity of managing vast numbers of policies led to the development of **Automated Policy Management** software, which streamlines repetitive steps:

- **Creation & Workflow:** Assists in drafting and tracking the workflow of policy approvals (signatures).
- **Distribution & Tracking:** Automatically publishes policies and tracks when employees have **read and agreed** to them, fulfilling a key legal and compliance requirement.

II. The Security Blueprint and Architecture

The **Security Blueprint** is the master plan for the security program. It serves as a comprehensive **design of the security architecture**, detailing the various controls and how they are integrated into the organization's environment.

Spheres of Security

The blueprint integrates security across three distinct areas of organizational focus:

Aspect	Sphere of Use (Human Element)	Sphere of Protection (Technical/Data)	Sphere of Safety (Physical/Environmental)

INFO SEC NU

Focus	Interaction of users with information	Security controls protecting information and systems	Physical and environmental security
Main Elements	Users, devices, processes	Data, systems, networks	Physical environment, infrastructure
Goal	Ensure secure usage and access	Maintain **Confidentiality, Integrity, and Availability (CIA)**	Protect against physical and environmental risks (e.g., fire, flood, theft)
Example Controls	Authentication, endpoint protection, AUP adherence	Firewalls, encryption, access control lists	Surveillance, fire suppression, backup power

Levels of Security Control

Security controls, as defined by the blueprint, are typically categorized by their focus:

1. **Managerial Controls:** Administrative safeguards focused on **planning, organizing, leading, and controlling** (e.g., policies, risk management, security governance). These are designed by strategic planners.
2. **Operational Controls:** Safeguards focused on the **functionality** of the organization's security (e.g., disaster recovery plans, incident response procedures, personnel security). These ensure day-to-day security operations run smoothly.
3. **Technical Controls:** Safeguards focusing on the **application of technology** to protect assets (e.g., firewalls, VPNs, IDPSs, anti-malware software, encryption).

Defense in Depth (DiD)

Defense in Depth is the fundamental strategy for security architecture.

INFO SEC NU

- **Concept:** It uses **multiple, layered, and different types of controls** (managerial, operational, and technical) to provide optimal protection.
- **Redundancy:** It incorporates **redundancy**, meaning multiple technologies or systems are used so that the failure of one system does not compromise the entire security posture.

The Security Perimeter and Domain

- **Security Perimeter:** The boundary between an organization's internal security efforts and the **outside world or untrusted network areas** (typically defined by the outermost firewalls and access controls).
- **Security Domain:** An **area of trust** within the organization where information assets share the same level of protection. Communication between different security domains (e.g., finance vs. R&D) is strictly regulated and monitored. The **Demilitarized Zone (DMZ)** is a common example of a security domain that sits between the external untrusted network and the internal trusted network.

III. Security Education, Training, and Awareness (SETA)

The SETA program is crucial because the **human element** remains the weakest link in the security chain. SETA ensures users are equipped to execute the operational and technical controls mandated by policy.

Attribute	**Education (Why)**	**Training (How)**	**Awareness (What)**
Level	**Insight** (Deep Understanding)	**Knowledge** (Practical Skill)	**Information** (Exposure)
Objective	Understanding complex security concepts	Developing a specific job **skill** securely	Keeping security at the **forefront** of users' minds
Teaching Method	Theoretical instruction, discussion, hands-on practice	Practical instruction, lecture, case studies	Posters, media, videos, newsletters

INFO SEC HUB

Impact Timeframe	**Long Term**	**Intermediate**	**Short Term** (Continuous reinforcement)

Continuity strategies: ensuring business resilience

Contingency Planning (CP) is the foundation for organizational resilience, comprising the actions and documented plans (**Contingency Plan**) that senior management takes to specify the organization's efforts and actions when an adverse event becomes an incident or a disaster.

I. The Components of Contingency Planning

CP integrates three primary plans, preceded by a crucial analytical step:

$$\text{Contingency Planning} \rightarrow \text{Business Impact Analysis (BIA)} \rightarrow \begin{cases} \text{Incident Response Plan (IRP)} \\ \text{Disaster Recovery Plan (DRP)} \\ \text{Business Continuity Plan (BCP)} \end{cases}$$

Plan	**Focus/Goal**	**Scope/Timeframe**	**Transition/Trigger**
Incident Response Plan (IRP)	**Immediate Response:** Detecting and correcting the impact of an **incident**.	Focuses on stopping the immediate attack/event and restoring normal operations at the original site.	If the incident escalates or the damage is severe, control moves to the DRP/BCP.
Disaster Recovery Plan (DRP)	**Restoration:** Restoring systems and operations (typically IT) at the **original site** after a disaster.	Focuses on minimizing the disruption and returning to a pre-disaster state once the threat is gone.	Closely associated with the BCP, often combined under Business Resumption Planning (BRP).

INFO SEC NU

Business Continuity Plan (BCP)	**Ongoing Operation:** Maintaining critical business functions when the **primary operating location is unusable** due to a disaster.	Focuses on sustaining business processes at an alternate site; occurs **concurrently** with DRP.	Activated when the primary location is rendered unusable or restoration will take significant time.

Crisis Management: This is a complementary function focusing on non-IT aspects, such as **minimizing injury or loss of life**, preserving the organization's image and market share, and public communications.

II. The Contingency Planning Management Team (CPMT)

Effective CP requires strong leadership and involvement from all communities of interest:

CPMT Member	Role and Responsibility
Champion	A high-level executive (ideally CEO or CIO) who **supports, promotes, and endorses** the CP findings. Provides the necessary **authority** and resources.
Project Manager	A mid-level manager or the **CISO** who leads the project, ensures a sound planning process, develops the complete project plan, and manages resources.
Team Members	Managers or representatives from the three communities of interest: **Business**, **Information Technology (IT)**, and **Information Security**.

INFO SEC NU

III. The Overall CP Process (Seven Steps)

The development of the overall Contingency Plan (integrating IRP, DRP, and BCP) follows a structured lifecycle:

1. **Develop the CP Policy Statement:** A formal policy providing the **authority and guidance** necessary for CP development.
2. **Conduct the Business Impact Analysis (BIA):** Identifies and **prioritizes** critical systems and business processes.
3. **Identify Preventive Controls:** Implement measures (like redundant systems or security controls) to **reduce the likelihood and effects** of system disruptions, increasing availability.
4. **Create Contingency Strategies:** Develop **thorough recovery strategies** to ensure quick and effective system recovery (e.g., site and data strategies).
5. **Develop the Contingency Plan:** Create the detailed guidance and procedures for restoring damaged facilities and systems, tailored to each business unit's requirements.
6. **Ensure Plan Testing, Training, and Exercises:**
    - **Testing** validates recovery capabilities.
    - **Training** prepares personnel for plan activation.
    - **Exercises** identify planning gaps.
    - Combined, these activities improve plan effectiveness.
7. **Ensure Plan Maintenance:** The plan must be a **living document** that is regularly updated to reflect changes in systems, organizational structure, and business processes.

IV. Business Impact Analysis (BIA)

The BIA is the crucial preliminary investigation and assessment that drives CP efforts.

BIA Function and Deliverables

- **Function:** To investigate and assess the various **adverse events** that can affect the organization.
- **Core Determination:** Measures **how critical a system or set of information is** to the organization's core processes and determines **recovery priorities**.
- **Key Output:** Identifies essential business units and processes, and establishes metrics like:
    - **Maximum Tolerable Downtime (MTD):** The longest an asset can be unavailable without causing irreparable harm.
    - **Recovery Time Objective (RTO):** The target time for restoring the business process after an outage.

INFO SEC NU

- **Recovery Point Objective (RPO):** The maximum tolerable data loss (time between the last good backup and the disaster).

V. Incident Response (IR) Planning and Phases

An **Incident** is an adverse event that is directed against information assets, has a realistic chance of success, and could threaten the CIA of resources. IRP focuses on detecting and correcting the immediate impact.

The Four Phases of IR

1. **Planning:** Developing the IR plan itself, including defining roles, procedures, and the transition criteria to DRP/BCP.
2. **Detection:** Identifying that an adverse event has become an incident (e.g., automated tools alerting, staff reporting).
3. **Reaction:** Actions to stop the incident and mitigate impact.
    - **Notification of Key Personnel:** Using an **alert roster** (hierarchical or sequential) and an **alert message** (a scripted description) to quickly inform necessary personnel.
    - **Documenting an Incident:** Recording the **who, what, when, where, why, and how** for forensic and post-incident analysis.
    - **Incident Containment Strategies:** The **first priority** is to stop the spread. Strategies include severing affected communication circuits, disabling compromised accounts, reconfiguring firewalls, or temporarily disabling services.
4. **Recovery:** Actions taken once the incident is contained and control is regained.
    - **Damage Assessment:** Determining the scope and extent of the damage.
    - **Recovery Actions:** Identifying and resolving vulnerabilities, addressing failed safeguards, evaluating monitoring, restoring data from backups, restoring services, and restoring confidence.
    - **Backup Media:** Utilizing various solutions (local media, tape arrays, online/cloud backup) for data restoration.
    - **Automated Response:** Deploying technologies that can respond to threats autonomously based on preconfigured options.

VI. Disaster Recovery (DR) and Business Continuity (BC)

Disaster vs. Incident

Concept	Severity/Scope	Impact on Operations	Recovery Focus

INFO SEC NU

Incident	Smaller scale, manageable with local resources.	Disrupts normal operations but does not exceed local recovery capacity.	Immediate containment and restoration at the **original site**.
Disaster	Severe and widespread event, overwhelms local resources.	Inability to mitigate impact; requires **external assistance** and coordinated long-term effort.	**Long-term restoration** (DRP) and maintaining continuity at an **alternate site** (BCP).

Site and Data Contingency Strategies

Choosing the right alternate site is a major component of DRP and BCP:

- **Hot Site:** A fully configured, ready-to-use alternate facility, including furniture, equipment, and services, offering the **fastest recovery time**.
- **Warm Site:** A facility with networking hardware and necessary office space, but not fully configured systems. Requires more setup time than a hot site.
- **Cold Site:** A bare bones facility with basic infrastructure (power, cooling) but no equipment. It is the **cheapest** but has the **longest recovery time**.

Risk Identification: Knowing What to Protect

Risk Management is the overall process of identifying risk, assessing its magnitude, and applying controls to reduce it to an acceptable level.

The amount of risk an organization is willing to tolerate is its **risk appetite**. Any risk remaining after applying controls is known as **residual risk**.

The three major undertakings of Risk Management are:

1. **Risk Identification:** Enumerating and documenting risks to assets.
2. **Risk Assessment:** Determining the extent of exposure to risk.
3. **Risk Control:** Applying controls to reduce risks to an acceptable level.

I. Components of Risk Identification

Risk Identification is a structured process that establishes the foundation for the entire risk management effort.

INFO SEC NU

1. Planning and Organizing the Process

- The process begins by forming a **Risk Management team**, usually composed of representatives from all affected business units (communities of interest).
- The entire risk management project must be **planned**, including scheduled deliverables, periodic reviews, and formal presentations to management.

2. Identifying, Inventorying, and Categorizing Assets

This is an **iterative process** to identify and catalog all organizational assets, which are the recipients of security protection. These assets include: **People, Procedures, Data, Software, Hardware, and Networking elements.**

A. Asset Attributes to Track

Asset Category	Key Attributes to Track
People	Position name/ID (using roles, not names); supervisor; **security clearance level**; special skills.
Procedures	Description; intended purpose; relationship to other assets (software/hardware); storage location (for reference and update).
Data	**Classification** (Confidential, Internal, etc.); owner/creator/manager; size; structure type (sequential/relational); location (online/offline); backup procedures.
Hardware, Software, & Network	Name; IP/MAC address; element type; serial number; manufacturer; model/version; physical/logical location; **controlling entity**.

B. The Asset Inventory

- Creating an inventory is critical for understanding **what** the organization is protecting and **where** that information is stored.

INFO SEC NU

- The inventory must include **all forms of information**, not just digital data (e.g., hard copy documents in filing cabinets, sensitive information in employee hands).

3. Classifying, Valuing, and Prioritizing Assets

Assets must be classified and valued so that protection efforts are proportional to the importance of the asset.

A. Data Classification and Clearance

A **Data Classification Scheme** is a formal access control methodology used to assign a level of confidentiality to information assets, restricting access on a "need-to-know" basis.

Classification	Description	Access
Confidential	Most sensitive corporate information. Access is **strictly on a need-to-know basis** or required by contract terms. May be referred to as "sensitive" or "proprietary."	
Internal	All internal information not meeting the confidential criteria. To be viewed only by corporate employees, authorized contractors, and third parties.	
External	Information formally approved by management for **public release**.	

- **Security Clearance:** A corresponding status level assigned to employees, designating the **maximum level of classified data they are permitted to access**.

B. Management of Classified Data

- **Clean Desk Policy:** Requires employees to inspect work areas and ensure all classified materials are **secured** (locked away) at the end of every workday.
- **Dumpster Diving:** An attack method involving searching through an organization's trash for sensitive, improperly discarded information.

INFO SEC NU

C. Information Asset Valuation

Asset Valuation is the process of assigning a financial value or worth to each information asset based on multiple criteria, including:

- **Criticality:** Is it critical to the organization's success or service delivery?
- **Revenue:** Does it generate the most revenue?
- **Replacement Cost:** How expensive is it to replace or restore?
- **Protection Cost:** How expensive is it to protect effectively?
- **Liability:** Would its revelation expose the company to legal liability or embarrassment?

4. Identifying and Prioritizing Threats

A **Threat Assessment** is an evaluation of potential threats to assets, determining their potential to endanger the organization.

The assessment requires answering basic questions:

- Which threats are a realistic danger in the current environment?
- Which threats represent the most danger to the organization's information?
- How much would it cost to **recover** from a successful attack (impact)?
- How much would it cost to **prevent** the attack (control expense)?

5. Specifying Asset Vulnerabilities

Vulnerabilities are flaws or weaknesses in an asset (hardware, software, procedure, design, or control) that a threat agent can exploit to breach security.

The final step in Risk Identification is compiling the **Threats-Vulnerabilities-Assets (TVA) Worksheet**. This document shows a comparative ranking of:

$$\text{Prioritized Assets} \quad \text{vs.} \quad \text{Prioritized Threats} \quad \text{with} \quad \text{Identified Vulnerabilities}$$
This matrix provides the actionable input needed for the next phase: **Risk Assessment**, where the calculated risk is quantified.

Risk Assessment and Control

I. Risk Assessment: Quantifying Risk

Risk Assessment is the process of evaluating the relative risk for each asset-vulnerability pair by determining the probability of a successful attack and the financial impact of that loss. It assigns a **risk rating or score** to prioritize protection efforts.

INFO SEC NU

1. The Risk Assessment Process

The assessment flows through these main steps:

1. **Plan and Organize:** Establish the methodology for evaluating the relative risk of each vulnerability.
2. **Determine Loss Frequency:** Calculate how often a specific loss event is expected to occur.
3. **Evaluate Loss Magnitude:** Determine the financial impact or severity of a single loss event.
4. **Calculate Risk:** Combine frequency and magnitude to arrive at the total expected loss.
5. **Assess Risk Acceptability:** Compare the calculated risk (residual risk) against the organization's risk appetite.

2. Key Risk Calculation Formulas (Quantitative Assessment)

Quantitative risk assessment attempts to assign **absolute numerical measures** to the elements of risk, primarily based on the estimated costs associated with losses and safeguards.

Term	Definition	Calculation/Relationship
Asset Value (AV)	The monetary value of the information asset.	-
Exposure Factor (EF)	The expected **percentage of loss** that would occur from a particular attack.	Expressed as a percentage (e.g., 0.1 for 10% loss).
Single Loss Expectancy (SLE)	The calculated monetary loss from a **single successful attack**.	$SLE = AV \times EF$

INFO SEC NU

Annualized Rate of Occurrence (ARO)	The expected **frequency of an attack** per year.	A value (e.g., 0.2 means one successful attack every 5 years).
Annualized Loss Expectancy (ALE)	The expected **annual loss** from a specific asset-threat pair. This is the **calculated risk**.	$ALE = SLE \times ARO$

General Risk Formula (Conceptual):

$$\text{Risk} = \text{Probability of Occurrence} \times \text{Impact or Severity of the Event}$$

3. Assessing Risk Acceptability

Once the risk (ALE) is calculated:

- **Residual Risk:** The amount of risk that **remains** to an asset even after the organization has implemented existing controls.
- **Risk Appetite:** The amount of risk management is **willing to accept**.
- The project team ranks the vulnerabilities in the **Ranked Vulnerability Risk Worksheet** and compares the residual risk to the risk appetite to determine if further action (Risk Control) is required.

II. Risk Control: Applying Controls

Risk Control is the application of controls to reduce residual risks to an acceptable level. It involves selecting strategies, justifying the costs, and implementing/monitoring the controls.

1. Selecting Control Strategies

The project team must select one of five basic strategies for addressing each asset-vulnerability risk:

Strategy	Action	Focus	NIST SP 800-30 Rev. 1 Terminology

INFOSEC NU

Defense	Attempts to **eliminate or reduce** the risk by applying additional controls and safeguards.	Prevention, Reduction. Achieved via policy, education, and technology.	Treat
Transfer	Attempts to **shift residual risk** to other entities (e.g., insurance companies, vendors, or partner organizations).	Shifting Liability/Responsibility.	Risk Transference
Mitigation	Attempts to **reduce the impact** of a successful attack through planning and preparation (e.g., Incident Response, Disaster Recovery).	Planning and Recovery.	Risk Limitation and Risk Planning
Acceptance	Indicates the organization is willing to **tolerate the current level of residual risk** without spending more on controls.	Conscious Tolerance. Used when the cost of control is greater than the expected loss.	Risk Assumption / Toleration
Termination	Eliminates all risk associated with an asset by **removing it from service** (e.g., decommissioning an outdated, vulnerable server).	Removal, Avoidance.	Risk Avoidance / Termination

INFO SEC NU

2. Justifying Controls (Cost-Benefit Analysis - CBA)

To justify spending organizational funds on new controls, a **Cost-Benefit Analysis (CBA)**, or economic feasibility study, is performed. The CBA contrasts the economic expenditures (Annualized Cost of a Safeguard) against the projected economic value (reduction in Annualized Loss Expectancy) it provides.

$$\text{CBA Value} = \text{ALE}_{\text{prior}} - \text{ALE}_{\text{post}} - \text{ACS}$$

- **ALE$_{\text{prior}}$:** ALE before implementing the new safeguard.
- **ALE$_{\text{post}}$:** New, lower ALE estimated *after* implementing the safeguard.
- **ACS (Annualized Cost of a Safeguard):** The total annual cost of the control (purchase, maintenance, support fees).
- **A positive CBA Value means the control is economically justifiable.**

3. Implementation, Monitoring, and Assessment

The final steps involve putting the chosen controls into action and maintaining a continuous security lifecycle:

- **Implementation:** Deploying the selected risk control strategy and safeguards.
- **Monitoring and Assessment:** Continuously evaluating the controls' effectiveness to accurately determine the **estimated residual risk**.
- **Qualitative Assessment:** Uses categorical or non-numeric values (e.g., High, Medium, Low) for subjective evaluations.
- **Quantitative Assessment:** Uses numerical measures (e.g., $ALE) for financial justification.
- **Benchmarking and Best Practices:** Comparing the organization's security posture and processes against industry peers (benchmarking) and adopting superior methods (best business practices) to close any identified **performance gaps**.

INFO SEC NU